



SR 816.111

Anhang 8 der Verordnung des EDI vom 22. März 2017 über das elektronische Patientendossier

Technische und organisatorische Zertifizierungsvoraussetzungen für Identifikationsmittel und deren Herausgeber

Technical and organizational Certification Requirements for Electronic Authentication Means and Their Issuers

Anhang 8 EPDV-EDI

:

Zertifizierungsvoraussetzungen für Identifikationsmittel und deren Herausgeber

Ausgabe 7: 30. April 2026

Inkrafttreten: 1. Juni 2026

Table of contents

1	Introduction	3
1.1	Definition of terms	3
1.2	Certification Scope	4
1.3	Organization of the document	4
2	General Requirements	5
2.1	Introduction	5
2.2	Organizational Requirements	5
2.3	Authenticator Requirements	5
2.4	Issuance Requirements	6
2.5	Identity Proofing Requirements	7
2.5.1		8
2.5.2		8
2.5.3		8
2.5.3a	Authorized identification evidences	8
2.5.3b	Authorized identification procedures	8
2.5.4	Address confirmation	8
2.5.5	GLN confirmation	9
3	Information Security Management	10
4	Protocol Requirements	11
4.1	SAML 2.0 Binding	11
4.1.1	Sequences	11
4.1.2	Protocol Requirements	13
4.1.3	Messages	14
4.2	OpenID Connect	17
4.2.1	Sequences	18
4.2.2	Protocol Requirements	19
4.2.3	Messages	20
5	Appendix	26
5.1	List of tables	26
5.2	List of figures	26
5.3	Acronyms	26
5.4	Glossary	26

1 Introduction

Das Bundesgesetz über das elektronische Patientendossier (EPDG) verlangt für den Zugriff auf das elektronische Patientendossier (EPD) durch Patientinnen und Patienten sowie durch Gesundheitsfachpersonen eine starke Authentifizierung als Grundlage für eine vertrauenswürdige Identität. Dazu legt das Ausführungsrecht zum EPDG die Anforderungen für die elektronische Identität sowie für den Ausgabeprozess von IDM fest. Um ein hohes Vertrauen in die behauptete Identität von Patientinnen und Patienten sowie Gesundheitsfachpersonen sicherzustellen, müssen die Prozesse für die Registrierung, Verwaltung und Herausgabe von IDM die Anforderungen nach Vertrauensstufe 3 (Level of Assurance 3) der Norm ISO / IEC 29115:2013 erfüllen.

Die technischen und organisatorischen Zertifizierungsvoraussetzungen an die Identifikationsmittel und deren Herausgeber nach Artikel 31 Absatz 2 der Verordnung über das elektronische Patientendossier (EPDV) werden in diesen Zertifizierungskriterien konkretisiert. Die Zertifizierungskriterien definieren die Anforderungen für alle Produkte, welche die elektronische Identifizierung und Authentifizierung für den Zugriff auf die Schweizerische EPD durchführen.

The Swiss Federal Act on Electronic Patient Records (EPRA) requires a strong authentication as the basis for trusted identities for patients and healthcare professionals in order to access the Electronic Patient Record (EPR). To this end, the ordinance for the EPRA (EPRO) sets the requirements concerning electronic identities and the issuing process for Electronic Identification Means (EIM). To assure high confidence in the claimed identity of patients and healthcare professionals, the related processes for registration, management and issuance of EIM have to comply with the requirements of Level of Assurance 3 (LOA 3) of ISO / IEC 29115:2013.

The technical and organizational certification requirements concerning EIM and their issuers in accordance with article 31 paragraph 2 of the EPRO, are specified in this document. All products performing electronic identification and authentication for the access to the Swiss EPR have to fulfil the requirements specified in this document.

1.1 Definition of terms

Relying Party: A Relying Party is understood as any actor that relies on an identity claim provided by an Identity Provider for user authentication. In the context of the EPR, Relying Parties are in particular medical information systems and portals for patients and healthcare professionals, which access data and documents from the EPR^{1,2}.

Identity Provider: An Identity Provider is understood as a legal entity which manages the Subscriber's primary authentication credentials and issues authenticators and assertions derived from those credentials. Identity Provider typically operate the Verifier and the Credential Service Provider, but may delegate the services to other provider on a contractual basis.

Verifier: A verifier is understood as any Actor that corroborates identity information, by verifying the claimant's identity by verifying the claimant's possession and control of authenticators using an authentication protocol (see fn. 1 or 2).

Credential Service Provider: A Credential Service Provider is understood as actor which registers, verifies and provides assertion attributes of Subscriber. The Credential Service Provider typically operates Registration and Local Registration Authorities, but may delegate the services to other provider on a contractual basis (see also fn. 2).

Registration Authority: A Registration Authority is understood as a trusted actor that establishes and/or vouches for the identity claims of an entity to an Identity Provider. The Registration Authority may be an integral part of an Identity Provider, or it may be independent of an Identity Provider, but has a relationship to the Credential Service Provider (see fn. 1 or 2).

¹ ISO/IEC 29115:2013: Information technology -- Security techniques -- Entity authentication assurance framework.

² NIST Special Publication 800-63-4, Digital Identity Guidelines, July 2025 including updates as of February 2020.

Local Registration Authority: A Local Registration Authority is understood as a legally independent organization that establishes and/or vouches for the identity claims of an entity on behalf of a Registration Authority to an Identity Provider. In the context of the EPR Local Registration Authorities in particular are entities which are integrated in healthcare organizations as hospitals, rest homes or communities. All organizations that run a Local Registration Authority do so on a delegated authority basis from Registration Authority.

Applicant: A user applying for authentication means. The Applicant becomes a Subscriber if identified and in possession of a valid authenticator.

Claimant: A user claiming the identity of a Subscriber using an authentication protocol. The Claimant becomes a Subscriber after successful authentication.

Subscriber: A user who is properly identified and has received authentication means from an Identity Provider, Registration Authorities or Local Registration Authority.

The key words "MUST", "MUST NOT", "REQUIRED", "SHALL", "SHALL NOT", "SHOULD", "SHOULD NOT", "RECOMMENDED", "MAY", and "OPTIONAL" in this document are to be interpreted as described in RFC 2119³.

1.2 Certification Scope

This document defines the certification criteria for Identity Provider, Registration and Local Registration Authorities for the EPR. The certification criteria cover the requirements for the services towards the user of the EPR (patients, healthcare professionals, assistants and administrators of the communities) and the requirements for the IT Systems used by Identity Provider, Registration and Local Registration Authorities to provide the services towards the users. IT systems acting as Relying Parties are out of scope of the certification.

1.3 Organization of the document

The document is organized as follows:

Section 2 lists the general requirements on Identity Provider, Verifier, Registration and Local Registration Authorities towards the users of the EPR (patients, healthcare professionals, assistants and administrators of the communities) and the Relying Parties.

Section 3 defines the technical and operational requirements for the authenticator, the verifier and the credential service provider operated by the Identity Provider to provide the services towards the users.

Section 4 describes the technical requirements on the protocols to be used by Verifier, Credential Service Provider and the Relying Parties to provide endpoints for secure communication.

³ <https://www.rfc-editor.org/rfc/rfc2119> (Accessed 11. Nov. 2022).

2 General Requirements

2.1 Introduction

This section describes the general requirements on Identity Provider, Credential Service Provider, Verifier, Registration and Local Registration Authorities.

2.2 Organizational Requirements

For secure operation of an identification- and identity management system the Identity Provider, Verifier, Registration and Local Registration Authorities SHALL establish and maintain the following controls:

- a. Registration and Local Registration Authorities SHALL establish processes to maintain the accuracy of the identity information and controls to verify policies, regulations, business requirements and to improve procedures.
- b. A documented process for validating and authorizing Local Registration Authorities according to an appropriate Registration Authority Policy with its information security requirements SHALL be established and implemented.
- c. The Registration Authorities SHALL ensure high security level processing for all Local Registration Authorities according to the appropriate policy. There SHALL be agreements between the Registration Authority and the Local Registration Authorities to maintain the claimed security level.
- d. Registration and Local Registration Authorities SHALL ensure the reliability of the parties involved in the identification and registration process. Particularly, the personnel involved in the non-IT and IT-based actions for Identification and registration have to be trustworthy as defined in the Registration Authority Policy.
- e. Registration and Local Registration Authorities SHALL ensure that the identification and registration process is appropriately hardened against eavesdropping and manipulation. Therefore, the Registration Authorities SHALL define within the agreements on which way the Local Registration Authorities SHALL transfer the registration data.
- f. The data transfer between the Registration and Local Registration Authorities and the Verifier and Credential Service Provider SHALL be hardened against eavesdropping and manipulation, either by using mutual authenticated, protected and ciphered channels for electronic communication (IPsec, mutual TLS 1.2 or higher, TLS 1.2 or higher with message level authentication) or by using postal services.
- g. The formal process-flow including the interfaces for requesting the registration and/or providing information by the Applicant SHALL be defined and verified by the Registration Authorities.
- h. Training requirements for personnel validating evidence SHALL be based on the policies, guidelines, or requirements of the Registration Authorities.
- i. Registration and Local Registration Authorities SHALL require operators to have undergone a training program to detect potential fraud and to properly perform resolution, validation and verification of identity information.

2.3 Authenticator Requirements

Identity Provider SHALL provide an authenticator compliant with Level of Assurance 3 (LOA 3) of ISO/IEC 29115:2013 (fn. 1) and Identity Assurance Level 2 (IAL 2) of NIST Special Publication 800-63B-4 (fn. **Fehler! Textmarke nicht definiert.**).

The authenticators provided by the Identity Provider SHALL either be a multi-factor authenticator or a combination of two single-factor authenticators.

The following multi-factor authenticator types are permitted:

- a. Multi-Factor OTP Device.
- b. Multi-Factor Cryptographic Device.
- c. Multi-Factor Cryptographic Software.

When a combination of two single-factor authenticators is used, it SHALL include a Memorized Secret authenticator and one possession-based authenticator from the following list:

- d. Look-Up Secret.
- e. Out-of-Band Device.
- f. Single Factor OTP Device.
- g. Single-Factor Cryptographic Device.
- h. Single-Factor Cryptographic Software.

Biometrics SHALL be used only as part of multi-factor authentication, when combined with a physical authenticator.

The following controls SHALL be applied and fulfilled:

- i. ISO/IEC 29115:2013 (fn. 1): 6.3 Level of assurance 3 (LoA3).
- j. NIST SP 800-63-3 B (fn. **Fehler! Textmarke nicht definiert.**): 2.2 Authentication Assurance Level 2.
- k. ...

[NOTE] Authenticators for which known practical attack scenarios exist are not allowed.

[NOTE] Final decisions for applicability of authenticators are with the certification body.

2.4 Issuance Requirements

Registration and Local Registration Authorities SHALL fulfil the following requirements prior to, during and after the registration of the Applicant/Subscriber:

- a. The Registration and Local Registration Authorities SHALL maintain a record, including audit logs, of all steps taken to verify the identity of the Applicant and SHALL record the types of identity evidence presented in the proofing process.
- a^{bis}. The Registration and Local Registration Authorities MAY for further verification purposes store separately a copy of the presented identity evidence as means of proof.
- b. Collection of personally identifiable information SHALL be limited to the minimum necessary to validate the existence of the claimed identity and associate the claimed identity with the Applicant providing identity evidence for appropriate identity resolution, validation, and verification. This MAY include attributes that correlate identity evidence to authoritative sources.
- c. All personally identifiable information collected as part of the enrollment process SHALL be protected by the Registration and Local Registration Authorities to ensure confidentiality, integrity, and correct assignment of the information source.
- d. All relevant records in particular personally identifiable information SHALL be protected by the Registration and Local Registration Authorities from loss, destruction, falsification, unauthorized access and unauthorized release.
- e. The Registration and Local Registration Authorities SHALL establish processes to maintain the accuracy of the identity information and controls to verify policies, regulations, business requirements and to improve procedures.
- f. The Registration and Local Registration Authorities SHALL implement a user interface for Subscriber to access their identity information according to a specified policy.
- g. Before an Applicant enters into a contractual relationship with a Registration Authority or Local Registration Authority, the Applicant SHALL be informed of the precise terms and conditions regarding the use of the type of authentication factor.
- h. The terms and conditions SHALL be delivered by the Registration and Local Registration Authorities and SHALL be accepted by the Applicant.
- i. The Registration and Local Registration Authorities SHALL record the agreement with the Subscriber.
- j. Registration and Local Registration Authorities SHALL provide effective mechanisms for redress of Applicant/Subscriber complaints or problems arising from the identity proofing.

- k. The Registration and Local Registration Authorities SHALL perform all identity proofing in accordance with the published identity proofing policy and ensure, that Applicants/Subscriber are properly identified and registered based upon authoritative sources. This policy SHALL specify the particular steps taken to verify identities and SHALL also include control information detailing how the Registration and Local Registration Authorities handle proofing errors that result in an Applicant not being successfully enrolled. For example, the number of retries allowed, proofing alternatives (e.g., in-person if remote fails), or fraud countermeasures when anomalies are detected.
- l. The Registration and Local Registration Authorities SHALL revoke or destroy credentials/authenticators (including those based on shared secrets) based on a unique identifying attribute (e.g. serial number) within a maximum of 5 years from the date of issuance or immediately, when compromised or stolen.
- m. An on-line revocation/status checking availability SHALL be implemented and maintained as well as a web site, on which revocation requests can be submitted in an authenticated manner (security questions, out-of-band notification, etc.) by the Subscribers. If a Subscriber loses all authenticators or a factor necessary to complete multi-factor authentication and has been identity proofed, the Registration Authority SHALL revoke this authenticator.
- n. The Registration and Local Registration Authorities SHALL establish suitable policies for renewal and replacement of credentials. To renew credentials, the Subscriber SHALL authenticate using their existing, unexpired authenticator and credential to request issuance of a new authenticator and credential. If the subscriber fails to request authenticator and credential re-issuance prior to their expiration or revocation, the Subscriber SHALL be required to repeat the enrollment process to obtain a new authenticator and credential.

The following controls SHALL be applied and fulfilled (the symbol "# + Number" refers to respective *Controls for Threats* as defined in ISO/IEC 29115:2013):

- o. ISO/IEC 24760-2⁴: 6.3.2: Processes to maintain the accuracy of identity information
- p. ISO/IEC 24760-2: 6.3.3: Interface to access identity information
- q. ISO/IEC 24760-2: 6.3.5: Identity information quality and compliance
- r. ISO/IEC 29115 (fn. 1): 8.2.7: #17
- s. ISO/IEC 29115:10.1.2.1: #1
- t. ISO/IEC 29115:10.1.2.1: #3
- u. ISO/IEC 29115:10.1.2.1: #4 for humans [In-Person, Not-in-person]
- v. Biometric template protection in ISO/IEC 24745:2011. [See ISO/IEC 29115:10.2.2.1: #16].
- w. ISO/IEC 29115:10.2.2.1: #17, #18

2.5 Identity Proofing Requirements

This section specifies the requirements on identity proofing of users of the EPR (patients, healthcare professionals, assistants and administrators of the communities).

The following requirements are based upon ISO/IEC 29115 (fn. 1) for LoA3 and customized for the Swiss EPR.

⁴ ISO/IEC 24760-2:2015: Information technology — Security techniques — A framework for identity management — Part 2: Reference architecture and requirements.

2.5.1 ...⁵

2.5.2 ...⁶

2.5.3 ...⁷

2.5.3a Authorized identification evidences

The proofing of the identity of the users of the EPR SHALL fulfil the following requirements:

- a. Verify that the entity is in possession of one of the following evidences:
 - I. Swiss Passport,
 - II. Swiss Identity Card,
 - III. Swiss Residence Permit B, C, Ci, G or L for foreigner,
 - IV. A qualified electronic signature by a recognised certification service provider (ZertES, SR 943.03),
 - V. Swiss Residence Permit F, N, S.
- b. Verify that the presented identification evidence is genuine. All provided evidence must not be expired at the time of application.
- c. Protect all communication for identity proofing against eavesdropping by using a sufficiently secure and undisturbed environment.
- d. Protect all documents generated for identity proofing against loss or unauthorized use.

Identity Provider SHALL support all of the evidences listed above. Either, all Registration and Local Registration Authorities SHALL be able to verify the evidences, or SHALL be able to refer a claimant to a Registration or Local Registration Authority which is able to verify the evidence.

2.5.3b Authorized identification procedures

The following procedures are authorized for identifying users of the EPR (patients, healthcare professionals, assistants and administrators of the communities):

- a. Identity proofing of a natural person
- b. Attended remote identity proofing
- c. Unattended remote identity proofing
- d. Identity proofing using digital signature with certificate

The criteria for certifying the procedures for the identification outlined above must be defined in accordance with ETSI TS 119 461, section 9.2⁸.

2.5.4 Address confirmation

Address confirmation SHALL fulfil the following requirements:

- a. The Registration Authority SHALL send a notification of proofing to a confirmed address of record.
- b. The Registration Authority SHALL provide a valid enrollment code directly to the Subscriber or send to a confirmed and validated address of record for the Applicant if binding to an authenticator will occur at a later time.
- c. The Applicant SHALL present a valid enrollment code to complete the identity proofing process.

⁵ Repealed by the amendment EPDV-EDI of 31 July 2025.

⁶ Repealed by the amendment EPDV-EDI of 31 July 2025.

⁷ Repealed by the amendment EPDV-EDI of 31 July 2025.

⁸ ETSI TS 119 461, Technical specifications of the Electronic Signatures and Infrastructures (ESI); Policy and security requirements for trust service components providing identity proofing of trust service subject, February 2025, V2.1.1.

- d. If the enrollment code is also intended to be an authentication factor, it SHALL be reset upon first use.
- e. Enrollment codes SHALL have the following maximum validities:
 - I. 10 days, when sent to a postal address.
 - II. 10 minutes, when sent to a telephone (SMS or voice).
 - III. 1 hour, when sent to an email address.
- f. The Registration Authority SHALL ensure the enrollment code and notification of proofing are sent out-of-band to different addresses of record.

2.5.5 GLN confirmation

Identity Provider which provide the optional GLN in the identity assertion for healthcare professionals and assistants SHALL verify the authorization for practicing and the GLN against the cantonal or federal registers.

3 Information Security Management

Identity Provider, Registration and Local Registration Authorities SHALL implement and operate an Information Security Management System compliant to the standard ISO/IEC 27001 Information security, cybersecurity and privacy protection - Information security management systems - Requirements, Edition 3, 2022.

The Identity Provider, Registration and Local Registration Authorities prove the conformity of their information security management system with a certificate issued by a recognized body for ISO/IEC 27001:2022 certifications.

4 Protocol Requirements

4.1 SAML 2.0 Binding

Verifier SHALL provide trusted endpoints for Relying Parties implementing the SAML 2.0 Artifact Binding with Artifact Resolution Protocol via SOAP back-channel fulfilling the requirements defined in this section.

4.1.1 Sequences

4.1.1.1 Authentication

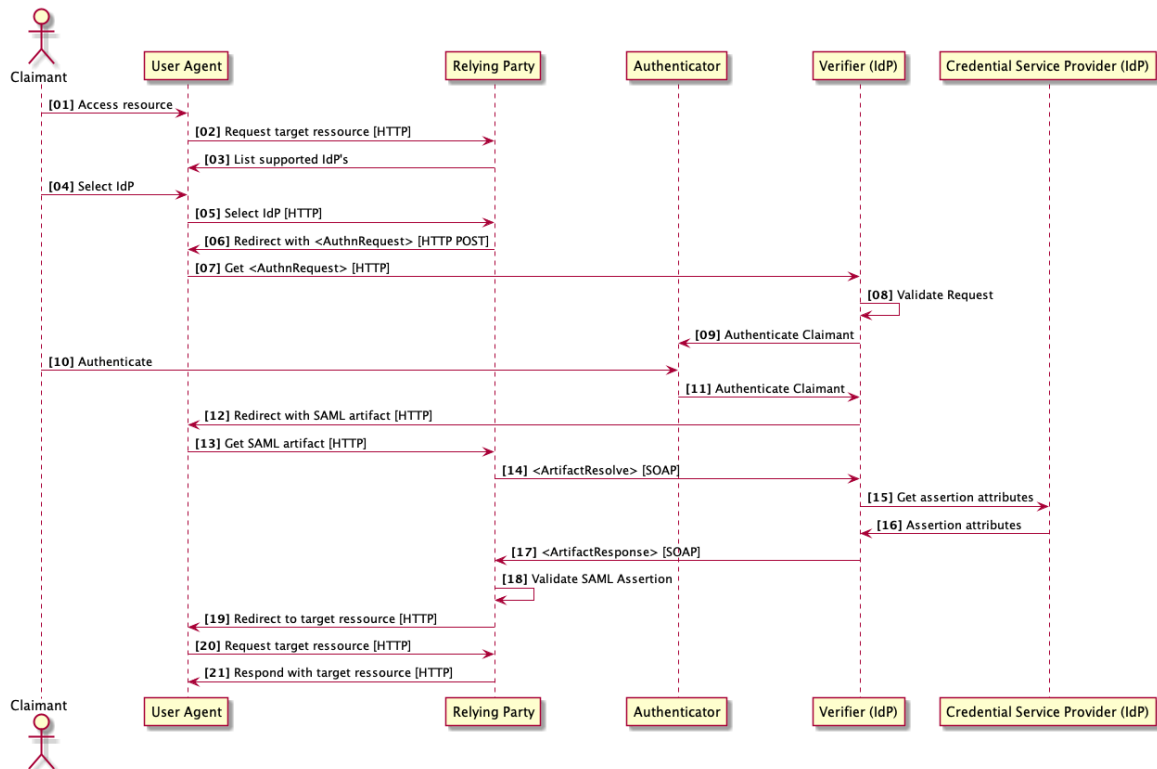


Figure 1: Authentication-Sequence with SAML 2 Artifact Binding

SEQ	Description
01,02	The Claimant's user agent attempts to access a resource on the relying party.
03	The Relying Party presents the list of supported Verifiers to the Claimant.
04,05	The Claimant selects a Verifier.
06,07	The Relying Party sends an HTML form back to the browser in the HTTP response (HTTP status 200). The HTML form contains a SAML <AuthnRequest> message encoded as the value of a hidden form control named SAMLRequest.
08	The Verifier determines whether the Claimant has an existing logon security context that meets the default or requested authentication policy requirements. If not, the Verifier interacts with the browser to challenge the Claimant to provide valid credentials.
09...11	The Verifier communicates with the Authenticator(s) to authenticate the Claimant. The Claimant provides valid credentials and the Verifier creates a local logon security context for the Claimant.
12,13	The Verifier creates an artifact containing the source ID for the relying party site and a reference to the <Response> message (the MessageHandle). The HTTP Artifact binding allows the choice of either HTTP redirection or an HTML form POST as the mechanism to deliver the artifact to the relying party. The figure shows the use of redirection.
14	The Relying Party determines the SAML requester by examining the artifact (the exact process depends on the type of artifact) and issues and send a <ArtifactResolve> request containing the artifact to the Verifier. This exchange is performed using a synchronous SOAP message exchange over the back-channel.

SEQ	Description
15,16	The Verifier extracts the MessageHandle from the artifact and requests the assertion or assertion attributes message associated with the artifact.
17	The Verifier returns the assertion with a SAML <ArtifactResponse> message as SOAP message via the back-channel to the Relying Party.
18...21	The Relying Party verifies the identity assertion retrieved with the <ArtifactResponse>. If the assertion is valid and the Claimant is authenticated, the Relying Party returns the requested resource to the Claimant's user agent.

Table 1: Authentication-Sequence with SAML 2 Artifact Binding

Relying Parties MAY renew SAML Identity Assertions for the duration of the Verifier's idle time of 2 hours after the assertion lifetime has expired without requiring a new authentication of the Claimant. To fulfill this requirement, the Verifier SHALL publish a web service endpoint, which implements a Security Token Service as defined in the WS-Security Standard⁹.

4.1.1.2 Renew

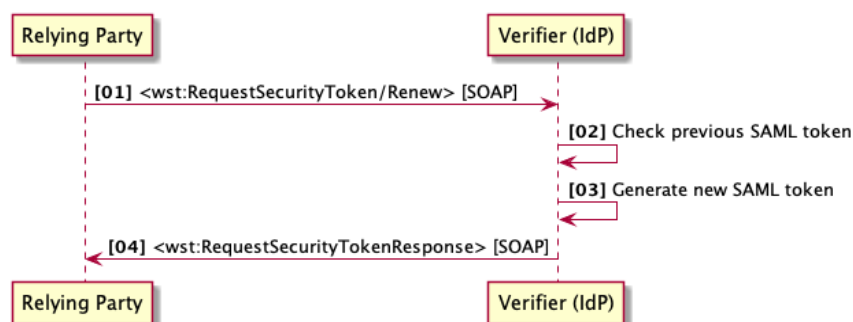


Figure 2: Renewal of a SAML-Assertion

SEQ	Description
01	The Relying Party uses the Identity Assertion of the Claimant in a <RequestSecurityToken> request as defined to the WS-Security Standard and sends it to the Verifier as SOAP version 1.1 request via the back-channel.
02	The Verifier validates the signature of the request and the signature of the assertion conveyed in the request.
03	The Verifier generates a new SAML Identity Assertion with a new expiration semantics according to chapter 6.3.
04	The Verifier embeds the generated SAML Identity Assertion in the <RequestSecurityToken-Response> according to the WS-Security Standard. Subsequently the Verifier sends this token as SOAP version 1.1 response message via the backchannel.

Table 2: Renewal of a SAML-Response-Assertion with new expiration semantics

4.1.1.3 Logout

The following requirements are based upon SAML Profiles 2.0¹⁰ Chapter 4.4 and are customized for the Swiss EPR.

The <LogoutRequest> and <LogoutResponse> transactions SHALL be protected to prevent attackers from unauthorized use. Verifier and Relying Parties shall fulfill the following requirements:

- Relying Parties SHALL cryptographically sign the <LogoutRequest> messages and the Verifier SHALL validate the signature with the public key of a pre-registered X.509 certificate.
- The X.509 certificate used by Relying Parties for signatures of the <LogoutRequest> message SHALL be issued by a managed Certificate Authority (CA) that is operated according

⁹ WS-Trust 1.3, A framework for requesting and issuing security tokens, OASIS Standard, March 2007.

¹⁰ Assertions and Protocols for the OASIS Security Assertion Markup Language (SAML) V2.0, March 2005: [saml-core-2.0-os].

to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS). The CA's processes should meet the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

- c. ...
- d. ...
- e. ...

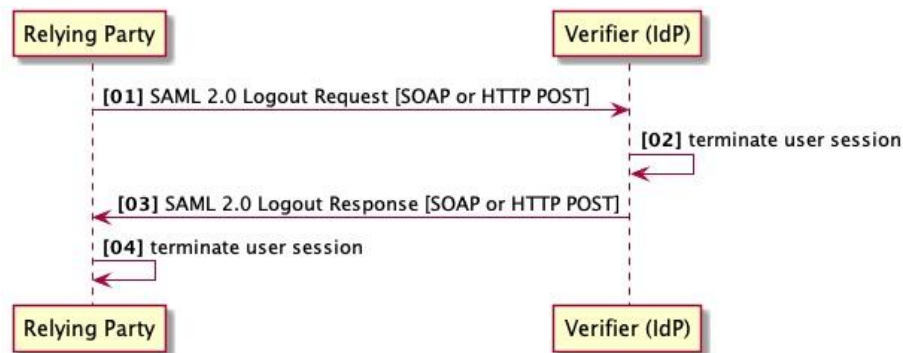


Figure 3: SAML 2.0 Logout Sequence

SEQ	Description
01	The Claimant initiates a logout in the user agent of the Relying Party application. The Relying Party sends a SAML 2 <LogoutRequest> message to the Verifier using the SAML 2 http POST or SOAP Binding.
02,03	The Verifier terminates the session and responds to the initial <LogoutRequest> with a <LogoutResponse> using the SAML 2 http POST or SOAP Binding.
04	The Relying Party terminates the user session.

Table 3: SSO Logout Sequence

4.1.2 Protocol Requirements

4.1.2.1 Front-channel Communication

The User Agent and the Verifier SHALL communicate through an authenticated protected channel using TLS 1.2 or higher. The User Agent can either authenticate itself with TLS Client authentication or using digital signature mechanisms on a message level.

The Verifier SHALL identify and authenticate itself with X.509 certificates which are issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss Accreditation Service (SAS).

Relying Parties and Authenticators which communicate with the Verifier through an intermediary user agent SHALL use digital signatures for message level authentication. The X.509 certificates used for signatures SHALL be issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS). The CA's processes SHALL meet the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

4.1.2.2 Back-channel Communication

The Verifier SHALL communicate with Relying Parties through an authenticated and protected back-channel (e.g., IPsec, TLS 1.2 or higher) for artefact resolution, token renew and logout. The Verifier SHALL identify and authenticate itself with TLS authentication or, when sending logout requests with message level authentication using X.509 certificates issued by a class 2 TLS certificate issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss Accreditation Service (SAS).

The Verifier SHALL NOT use redirects through an intermediary user agent (e.g., Web Browser) to communicate with Relying Parties for artefact resolution, token renew and logout.

Relying Parties SHALL use message level authentication (e.g., digital signature) to identify and authenticate. Relying Parties SHALL use X.509 certificates issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS) to identify and authenticate themselves for artefact resolution, token renew and logout. The CA's processes SHALL meet the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

4.1.3 Messages

4.1.3.1 Authentication Request

The <AuthnRequest> message SHALL be used by the Relying Party to initiate the authentication sequence.

The <AuthnRequest> message SHALL be cryptographically signed by the Relying Party and the Verifier SHALL validate the signature. The signature SHALL be asymmetric using X.509 certificates issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS). The CA's processes should meet the requirements of class 1 of the eCH-0048 PKI Certificate Classes standard (Version 2.0).

The signature SHALL either be validated with the public key of a pre-registered X.509 certificate, or the embedded certificate. If the public key of the embedded certificate is used, the Verifier SHALL verify, that the certificate matches the pre-registered one.

4.1.3.2 Authentication Response

The Authentication Response message SHALL be used by the Verifier as response to the <AuthnRequest> message to convey the artifact after authenticating the Claimant/Subscriber.

The Artifact conveyed with Authentication Response message SHALL

- a. Be for one-time-use only,
- b. Comply with saml-core-2.0-os chapter 3.5 (see fn.10),
- c. Comply with saml-profiles-2.0-os chapter 5¹¹.

The *SourceID* of the Artifact SHALL be the cryptographic hash of the *entityID* declared in the metadata made available by the Identity Provider. The cryptographic hash function SHALL be known to resist up to date attacks.

The Authentication response message SHALL be signed using recommended cryptographic signature standards. The signature SHALL be validated by the relying party. The X.509 certificate used for signatures by the Verifier SHALL be issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss Accreditation Service (SAS).

4.1.3.3 Artifact Resolve

The <ArtifactResolve> message SHALL be used by the Relying Party to resolve the artifact received with the <AuthenticationRequest> message to the SAML 2.0 Identity Assertion via the back-channel.

The <ArtifactResolve> message SHALL be cryptographically signed by the Relying Party and the Verifier SHALL validate the signature. The signature SHALL be asymmetric using X.509 certificates issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS). The CA's processes should meet the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

¹¹ Profiles for the OASIS Security Assertion Markup Language (SAML) V2.0, March 2005: [saml-profiles-2.0-os].

The signature SHALL either be validated with the public key of a pre-registered X.509 certificate, or the embedded certificate embedded. If the public key of the embedded certificate is used, the Verifier SHALL verify, that the certificate matches the pre-registered one.

4.1.3.4 Artifact Response

The <ArtifactResponse> message SHALL be used by the Verifier or Credential Service Provider to resolve the artifact received with the <ArtifactResolve> message to the SAML 2.0 Identity Assertion.

The Artifact response message SHALL be signed using recommended cryptographic signature standards. The signature SHALL be validated by the relying party. The X.509 certificate used for signatures by the Verifier SHALL be issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss Accreditation Service (SAS).

4.1.3.5 Assertion

The SAML 2.0 Assertion SHALL be used by the Verifier or Credential Service Provider to convey the identity data of an authenticated Claimant/Subscriber to the requesting Relying Party.

The SAML 2.0 Assertion SHALL contain the following attributes:

- a. First name with attribute name *http://schemas.xmlsoap.org/ws/2005/05/identity/claims/givenname*.
- b. Family name with attribute name *http://schemas.xmlsoap.org/ws/2005/05/identity/claims/surname*.
- c. Gender with attribute name *gender*.
- d. Date of birth with attribute name *dateofbirth*.

The attribute set MAY contain the GLN for healthcare professionals and assistants. If present, the GLN SHALL be contained in an <Attribute> element with the *Name* attribute set to "GLN".

The <NameID> in the SAML 2.0 Assertion SHALL be persistent and SHALL be unique for the combination of the Subscriber, the Community and the Identity Provider to reduce the risk of cross application identification. The <NameID> SHALL be confidential and never presented to the Claimant, the User Agent or third party systems.

The SAML 2.0 Assertions SHALL include a <SessionIndex> as element of the <AuthenticationStatement> to enable per session logout requests as defined in Section 4.1.4.2 of the SAML Profiles 2.0 specification (see fn. 11).

SAML 2.0 Assertions SHALL only be considered as valid within the time limits specified in the <NotBefore> and <NotOnOrAfter> attributes. Assertions SHALL expire 5 minutes after the assertion has been issued.

The data types used in SAML 2.0 Assertions SHALL be according to W3C XML Schema 1.0.

SAML 2.0 Assertions SHOULD use audience restriction techniques to allow a Relying Party to recognize whether or not it is the intended target of an issued assertion.

The SAML 2.0 Assertions SHALL be cryptographically signed and the Relying Party SHALL validate the signature. The signature SHALL be asymmetric using X.509 certificates issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss Accreditation Service (SAS).

4.1.3.6 Renew Request

Relying Parties MAY renew SAML Identity Assertions for the duration of the Verifier idle time after the assertion lifetime has expired without requiring a new authentication of the Claimant. To fulfill this requirement, the Verifier SHALL publish a web service compliant with the Web Services Trust standard (see fn. 9).

Relying Parties SHALL use an Identity Assertion of the Claimant in a <RequestSecurityToken> request as defined to the Web Services Security standard¹² and send it to the Verifier as SOAP version 1.1 request via the back-channel.

The Web Service security header of the SOAP envelope SHALL contain a security timestamp element as described in chapter 10 of the Web Services Security specification (see fn. 12). The security timestamp element SHALL be covered by the XML signature.

The security timestamp element SHALL contain a <Created> element whose value SHALL be the instant that the renew request is serialized for transmission as described in chapter 10 of the Web Services Security specification (see fn. 12). The security timestamp element SHALL contain an <Expires> element as described in chapter 10 of the Web Services Security specification (see fn. 12).

The Web Service security header of the SOAP envelope SHALL contain a binary token element as described in chapter 6.3 of the Web Services Security specification (see fn. 12). The binary token element SHALL have an encoding type attribute set to `EncodingType="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-soap-message-security-1.0#Base64Binary"`. The binary token element SHALL have a value type attribute set to `ValueType="http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-x509-token-profile-1.0#X509v3"`. The binary token element MAY have an <Id> attribute.

The Renew Request SHALL be cryptographically signed and the Verifier SHALL validate the signature. The signature SHALL be asymmetric using X.509 certificates issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS). The CA's processes should meet the requirements of class 1 certificates defined within the eCH-0048 PKI certificate classes standard (Version 2.0).

The Web Service security header of the SOAP envelope SHALL contain a signature element compliant to the XML signature specification and described in chapter 8 of the Web Service Security specification (see fn. 12). The signature method element SHALL reference a digest algorithm known to resist up to date attacks. The signature element SHALL contain a key info element with one child element conveying a security token reference conformal to the XML signature specification and described in chapter 7 of the Web Service Security specification (see fn. 12). The security token reference element SHALL convey the issuer name and serial number to identify the certificate. The SOAP body element of the request SHALL have an <Id> attribute which is referenced in the key info element of the SOAP security header as described above.

The Verifier SHALL

- a. Validate the signature of the request.
- b. Verify the request timestamp, discard any message whose security semantics have passed their expiration and respond with a fault code (<MessageExpired>).
- c. Verify the digest algorithm used with the request. The Verifier SHALL NOT accept deprecated digest algorithms, which do not resist up to date attacks.
- d. Validate the signature of the previous Identity Assertion conveyed with the <RequestSecurityToken> request.

4.1.3.7 Renew Response

The Renew Response message SHALL be used by the Verifier or Credential Service Provider to convey an updated SAML Identity Assertion in the <RequestSecurityTokenResponse> according to the WS-Security Standard (see fn.12) using SOAP version 1.1.

The Renew response message SHALL be signed using recommended cryptographic signature standards. The signature SHALL be validated by the relying party. The X.509 certificate used for signatures by the Verifier SHALL be issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss Accreditation Service (SAS).

¹² OASIS Web Services Security: SOAP Message Security 1.1, February 2006.

4.1.3.8 Logout Request

The <LogoutRequest> message SHALL be used by the Relying Party to notify the Verifier that a Claimant/Subscriber logged out in the Relying Party application.

SAML <LogoutRequest> messages SHALL include at least one <SessionIndex> as defined in Section 4.4.3.1 of the SAML Profiles 2.0 specification.

The <LogoutRequest> message SHALL be cryptographically signed by the sender and the receiver SHALL validate the signature. The signature SHALL either be validated with the public key of a pre-registered X.509 certificate, or the embedded certificate. If the public key of the embedded certificate is used, the Verifier SHALL verify, that the certificate matches the pre-registered one. The X.509-certificates used for signatures SHALL be issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS). The CA's processes should meet the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

Relying Parties SHALL sign <LogoutRequest> messages using X.509 certificates issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and a Certificate Practice Statement (CSP). The CA's process should meet the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

Verifier SHALL validate the signature of <LogoutRequest> messages.

4.1.3.9 Logout Response

The <LogoutResponse> message SHALL be used by the Verifier to confirm session termination to the initiating Relying Party.

Verifier SHALL sign <LogoutResponse> messages. The X.509 certificate used for signatures by the Verifier SHALL meet recommended cryptographic standards and must follow certificate lifecycle best practices detailed in a certificate policy and certificate practice statement.

Verifier SHALL verify the signature of <LogoutResponse> messages.

4.2 OpenID Connect

Verifier and Credential Service Provider SHALL provide trusted endpoints for Relying Parties implementing the OpenID Connect 1.0 Authorization Code Flow fulfilling the requirements defined in this section.

Other flows supported by OpenID Connect (i.e., Renew Flow, Hybrid or Implicit Flows) SHALL not be supported.

4.2.1 Sequences

4.2.1.1 User Authentication

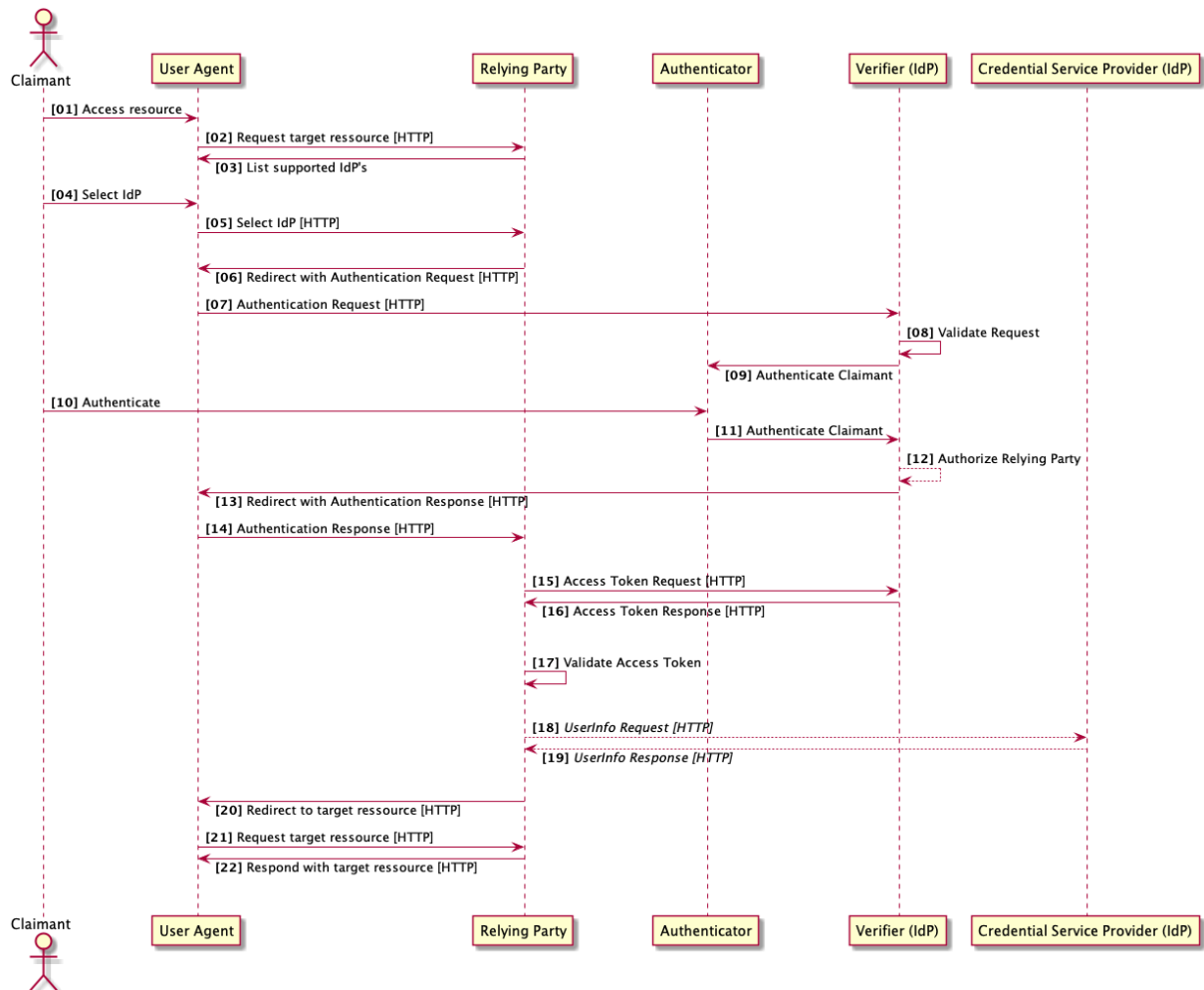


Figure 4: Authentication Sequence with OpenID Connect 1.0 Authorization Code Flow

SEQ	Description
01,02	The Claimant's user agent attempts to access a resource on the relying party.
03	The Relying Party presents the list of supported Verifiers to the Claimant.
04,05	The Claimant selects Verifier.
06	The Relying Party builds an Authentication Request containing the required request parameter and conveys it to the User Agent with a redirect to the authorization endpoint of the Verifier.
07	The User Agent sends the Authentication Request to the authorization endpoint via HTTP GET or POST protocol.
08	The Verifier determines whether the Claimant has an existing logon security context that meets the default or requested authentication policy requirements. If not, the Verifier interacts with the browser to challenge the Claimant to provide valid credentials.
09...11	The Verifier communicates with the Authenticator(s) to authenticate the Claimant. The Claimant provides valid credentials and the Verifier creates a local logon security context for the Claimant.
12	The Verifier presents a screen for the Claimant/Subscriber to authorize the Relying Party to retrieve the identity data. This step MAY be omitted if the Relying Party application is a confidential client as defined in the OAuth specification and the Claimant/Subscriber consent is stored in a policy or after the initial authorization.
13, 14	The Verifier creates an Authentication Response conveying the Authorization Code and sends the Authorization Response to the User Agent with a redirect to the Relying Party.

SEQ	Description
15	The Relying Party sends the Authentication Code to the Verifier in an Access Token Request using HTTP POST protocol and form serialization.
16	The Verifier identifies the Relying Party and sends an Access Token Response to the Relying Parties Redirection URI registered beforehand. The Access Token Response conveys an ID and an Access Token.
17	The Relying Party validates the ID Token and retrieves the Claimant's Subject Identifier.
18,19	Optionally the Relying Party uses the Access Token to retrieve user identity data using the OpenID Connect 1.0 UserInfo protocol.
20...22	The Relying Party returns the requested resource to the Claimant's user agent.

Table 4: Authentication Sequence with OpenID Connect 1.0 Authorization Code Flow

4.2.1.2 Logout

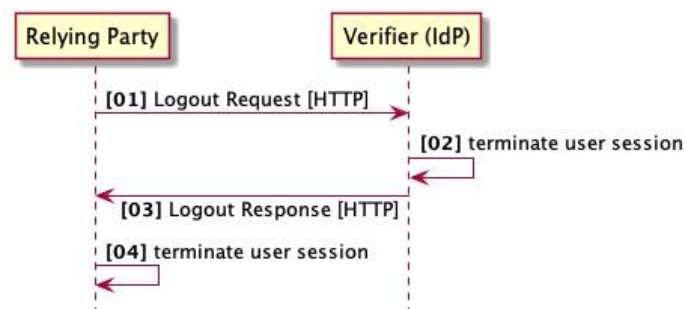


Figure 5: OpenID Connect Logout Sequence

SEQ	Description
01	The Claimant initiates a logout in the user agent of the Relying Party application. The Relying Party redirects the user agent with a Logout Request message to the Verifier Logout URI.
02, 03	The Verifier terminates the IdP session and responds to the initial Logout Request with a Logout Response using HTTP.
04	The Relying Party application terminates the user session.

Table 5: OpenID Connect Logout Sequence

4.2.2 Protocol Requirements

4.2.2.1 Front-channel Communication

The User Agent and the Verifier SHALL communicate through an authenticated protected channel using TLS 1.2 or higher. The Verifier SHALL identify and authenticate itself with X.509 certificates which are issued by a class 2 TLS certificate issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss Accreditation Service (SAS).

Relying Parties and Authenticators which communicate with the Verifier and Credential Service Provider through an intermediary user agent SHALL use digital signatures for message level authentication. The X.509 certificates used for signatures SHALL be issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS). The CA's processes SHALL meet the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

Relying Parties which fulfill the requirements of confidential clients of the OAuth 2.0 specification SHALL use digital signatures for message level authentication.

4.2.2.2 Back-channel Communication

The Verifier and the Credential Service provider SHALL communicate with Relying Parties through an authenticated and protected back-channel using TLS 1.2 or higher for access token and user info

requests and responses. The Verifier SHALL identify and authenticate itself with class 2 X.509 certificates issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss accreditation service (SAS).

Relying Parties SHALL fulfill the requirements of OAuth 2.0 confidential clients and SHALL use message level authentication (e.g., digital signature) to authenticate. Relying Parties SHALL use X.509 certificates issued by a managed Certificate Authority (CA) that are operated according to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS) to identify and authenticate themselves for access token and user info requests. The CA's processes should meet the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

The Verifier and the Credential Service Provider SHALL NOT use redirects through an intermediary user agent (e.g., Web Browser) to send requests to Relying Parties.

4.2.2.3 Client Authentication

If the Relying Parties provide confidential clients, the clients SHALL authenticate when performing Access Token Requests using the *private_key_jwt* option defined in Section 9 of the OpenID Connect Core 1.0 specification¹³.

4.2.3 Messages

4.2.3.1 Authentication Request

The Authentication Request message SHALL be used by the Relying Party to initiate the authentication sequence. The Authentication Request message SHALL be compliant with an OAuth 2.0 Authentication Request message.

Relying Parties which fulfill the requirements of confidential clients¹⁴ SHALL sign the Authentication Request message using JSON Web Signature¹⁵. The signature SHALL be asymmetric using X.509 certificates issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS). The CA's processes should meet the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

The Authentication Request SHALL contain the following parameters:

- a. *scope* – The value SHALL be *openid*.
- b. *response_type* – The value SHALL be *code*.
- c. *client_id* – The value SHALL be the Client Identifier the Relying Party was registered with at the Verifier.
- d. *redirect_uri* – SHALL convey the redirection URI the Access Token Response SHALL be sent to. Its value must match one of the redirection URI the Relying Party was registered at the Verifier.
- e. *state* – SHALL convey an opaque value used to maintain the state between the request and the response to mitigate Cross-Site Forgery attacks.
- f. *nonce* – SHALL convey an opaque string passed through from the Authentication Request to the ID Token to mitigate replay attacks.
- g. *code_challenge* – code challenge derived from the code verifier using the code challenge method as defined in PKCE¹⁶.
- h. *code_challenge_method* – code challenge method indicator defined in PKCE (fn. 16). Its value must be S256.

The Verifier SHALL validate the Access Token Request as follows:

¹³ OpenID Connect Core 1.0 incorporating errata set 1, November 2014.

¹⁴ The OAuth 2.0 Authorization Framework, RFC 6749, October 2012

¹⁵ JSON Web Signature (JWS), RFC 7515, May 2015.

¹⁶ Proof Key for Code Exchange by OAuth Public Clients, RFC 7636, September 2015

- i. Identify the client using the *client_id*.
- j. Verify the signature of the request if the Relying Party is registered as a confidential client.
- k. Verify that a secure cryptographic algorithm is applied.
- l. Authenticate the Relying Party, if the client application is registered as a confidential client.
- m. Validate the signature according to JSON Web Signature (see fn. 15) using the algorithm specified in the JWT *alg* Header Parameter.

4.2.3.2 Authentication Response

The Authentication Response message SHALL be used by the Verifier as response to the Authentication Request message to convey the authorization code after authenticating the Claimant/Subscriber. The Authentication Response message SHALL be compliant with an OAuth 2.0 Authentication Response message.

The Authentication Response SHALL contain the following parameters:

- a. *code* – SHALL be an OAuth 2.0 compliant authorization code.
- b. *state* – SHALL match the state parameter value of the Authentication Request.

In case of an error the Verifier SHALL respond a HTTP Error as defined in Section 3.1.2.6 of the OpenID Connect Core 1.0 specification (see fn. 13).

The authentication response message SHALL be signed using recommended cryptographic signature standards. The signature SHALL be validated by the relying party. The X.509 certificate used for signatures by the Verifier SHALL be issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss Accreditation Service (SAS).

4.2.3.3 Access Token Request

The Access Token Request message SHALL be used by the Relying Party to resolve the authorization code to the Access and ID Token. The Access Token Request message SHALL be sent via the backchannel. The Access Token Request message SHALL be compliant with an OAuth 2.0 Access Token Request message.

Relying Parties which fulfill the requirements of confidential clients (see fn. 14) SHALL sign the Access Token Request message using JSON Web Signature (see fn. 15). The signature SHALL be asymmetric using X.509 certificates issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS). The CA's processes should meet the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

The Access Token Request SHALL contain the following parameters:

- a. *grant_type* – The value SHALL be *authorization_code*.
- b. *code* – SHALL be the OAuth 2.0 compliant authorization code retrieved with the Authentication Response.
- c. *redirect_uri* – SHALL convey the redirection URI the Access Token Response SHALL be sent to. Its value must match the redirection URI sent with the Authentication Request.
- d. *code_verifier* – The code verifier value as defined in PKCE (fn. 16).

The Verifier SHALL validate the Access Token Request as follows:

- e. Identify the client using the *client_id*.
- f. Verify the signature of the request, if the Relying Party is registered as a confidential client, i.e. verify that a secure cryptographic algorithm is applied compliant with the JSON Web Signature (see fn. 15) specification.
- g. Authenticate the Relying Party, if the client application is registered as a confidential client.
- h. Verify that the authorization code was issued to the Relying Party in response to an Authentication Request.

- i. Verify that the authorization code was not used before.
- j. Verify that the value of the *redirect_uri* parameter send with the Access Token Request matches the one send with the Authentication Request.
- k. Verify that the value of the *redirect_uri* parameter send with the Access Token Request matches one of the redirection URIs registered for the Relying Party.
- l. Verify that the *code-verifier* matches the *code_challenge* send with the authentication request respecting the S256 code challenge method.

4.2.3.4 Access Token Response

The Access Token Response message SHALL be used by the Verifier convey the Access Token and the ID Token to the Relying Party in response the Access Token Request. The Access Token Response message SHALL be send via the backchannel. The Access Token Response message SHALL be compliant with an OAuth 2.0 Access Token Response message.

The Access Token Response SHALL contain the following parameters:

- a. *token_type* – The value SHALL be *Bearer*.
- b. *expires_in* – The Token lifetime in seconds. The value SHALL be equal to 300 (5 minutes).
- c. *access_token* – The value SHALL be an OAuth 2.0 compliant access token.
- d. *id_token* – The value shall be an Identity Token as defined below.

In case of an error the Verifier SHALL respond a HTTP Error as defined in Section 3.1.3.4 of the OpenID Connect Core 1.0 specification (see fn. 13).

The access token response message SHALL be signed using recommended cryptographic signature standards. The signature SHALL be validated by the relying party. The X.509 certificate used for signatures by the Verifier SHALL be issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss Accreditation Service (SAS).

4.2.3.5 Identity Token

The Identity Token SHALL be used by the Verifier to convey the Subject Identifier to the Relying Party. The Identity Token SHALL be compliant with the JSON Web Token¹⁷ and OpenID Connect Core 1.0 specification (see fn. 13).

Identity Tokens SHALL be cryptographically signed using JSON Web Signature (see fn. 15) and the Relying Party SHALL validate the signature. The X.509 certificate used for signatures by the Verifier SHALL be issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss Accreditation Service (SAS).

The Identity Token SHALL contain the following parameters:

- a. *iss* – The value SHALL be a unique identifier of the Issuer Credential Service Provider as URL.
- b. *sub* – The Subject Identifier of the Claimant/Subscriber.
- c. *aud* – The value SHALL be the Client Identifier the Relying Party is registered at the Verifier.
- d. *exp* – The time restricting the lifetime of the token lifetime. The value SHALL be equal to the current time plus 5 minutes.
- e. *iat* – The time the token was issued by the Verifier.
- f. *nonce* – The value SHALL match the *nonce* value of the Authentication Request.
- g. *jti* – The value shall be a unique identifier of the ID Token.

The Subject Identifier attribute SHALL be persistent and SHALL be unique for the combination of the Subscriber, the Community and the Identity Provider to reduce the risk of cross application identification. The Subject Identifier SHALL be confidential and never presented to the Claimant or third party systems.

¹⁷ JSON Web Token (JWT), RFC 7519, May 2015.

The Identity Token MAY contain a session identifier in a *sid* attribute, if the Identity Provider supports per session logout¹⁸.

The Identity Token MAY contain other claims which SHALL be ignored by the Relying Party.

The Relying Parties SHALL validate Identity Tokens as follows:

- h. Verify that the unique identifier of the Issuer matches the one registered for the Verifier.
- i. Verify that the value of the *aud* parameter matches the Client Identifier of the Relying Party.
- j. Validate the signature according to JSON Web Signature (see fn. 15) using the algorithm specified in the JWT *alg* Header Parameter.
- k. Verify that the signature algorithm matches the algorithm configured for the Verifier.
- l. Verify that the Identity Token is not expired and the current time is later or equal to the time the token was issued by the Verifier.
- m. Verify that a *nonce* claim is present and its value matches the one that was sent in the Authentication Request.

4.2.3.6 Userinfo Request

The Userinfo Request message SHALL be used by the Relying Party to retrieve identity data of the Claimant/Subscriber from the Credential Service Provider via the backchannel. The Userinfo Request message SHALL be compliant to the OpenID Connect 1.0 Userinfo Request message.

Relying Parties which fulfill the requirements of confidential clients (see fn. 14) SHALL sign the Userinfo Request message using JSON Web Signature (see fn. 15). The signature SHALL be asymmetric using X.509 certificates issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS). The CA's processes should meet the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

The Relying Party SHALL send the Access Token in the HTTP Authorization header field as Bearer Token as defined in The OAuth 2.0 Authorization Framework: Bearer Token Usage¹⁹.

The Credential Service Provider SHALL validate the User Info Request as follows:

- a. Validate the signature according to JSON Web Signature (see fn. 15) using the algorithm specified in the JWT *alg* Header Parameter.
- b. Verify that the signature algorithm matches the algorithm configured for the Relying Party at the Credential Service Provider.

4.2.3.7 Userinfo Response

The Userinfo Response message SHALL be used by the Credential Service Provider to respond with the identity data of the Claimant/Subscriber to Userinfo Requests from the Relying Party using back-channel communication. The Userinfo Response message SHALL be a JSON Web Token (JWT) compliant to the OpenID Connect 1.0 Userinfo Response message.

The Userinfo Response SHALL contain the following parameters:

- a. *first_name* – The first name of the Claimant/Subscriber.
- b. *family_name* – The family name of the Claimant/Subscriber.
- c. *gender* – The Claimants/Subscribers coded gender with the value from the value set EprGender (2.16.756.5.30.1.127.3.10.1.25).
- d. *birthdate* – The Claimants/Subscribers date of birth as ISO 8601-1:2019 formatted string.

If the Identity Provider delivers the GLN of healthcare professionals or assistants, the Userinfo Response SHALL contain a *gln* parameter conveying the GLN of healthcare professionals and assistants.

¹⁸ OpenID Connect Back-Channel Logout 1.0 - draft 06, August 2020.

¹⁹ The OAuth 2.0 Authorization Framework: Bearer Token Usage, RFC 6750, October 2012.

Credential Service Provider MAY provide other identity claims as defined in the OpenID Connect 1.0 Core specification (see fn. 13).

In case of an error the Credential Service Provider SHALL respond a HTTP Error as defined in Section 5.3.3 of the OpenID Connect Core 1.0 specification (see fn. 1313).

The UserInfo response message SHALL be signed using recommended cryptographic signature standards. The signature SHALL be validated by the relying party. The X.509 certificate used for signatures by the Verifier SHALL be issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss Accreditation Service (SAS).

4.2.3.8 Logout Request

The <LogoutRequest> message SHALL be used by the Relying Party to notify the Verifier that a Claimant/Subscriber logged out in the Relying Party application.

<LogoutRequest> messages send by the Relying Party to the Verifier SHALL be compliant with the OpenID Connect RP-Initiated Logout 1.0 specification²⁰ with the requirements defined in this section.

<LogoutRequest> messages SHALL contain a JWT with the following parameters:

- a. *id_token_hint* – SHALL convey the Identity Token previously issued by the Verifier.
- b. *state* – SHALL convey an opaque value used to maintain the state between the request and the response to mitigate Cross-Site Forgery attacks.

The JWT MAY contain other claims which SHALL be ignored by the Verifier.

Relying Parties which fulfill the requirements of confidential clients (see fn. 14) SHALL sign the <Logout Request> message using JSON Web Signature (see fn. 15). The signature SHALL be asymmetric using X.509 certificates issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and Certificate Practice Statement (CPS). The CA's processes should meet the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

The Verifier SHALL validate <LogoutRequest> messages as follows:

- c. Verify that the Identity Token was issued by the Verifier for the requesting client and user.
- d. Verify the signature of the Request Message, if the Relying Party was registered as confidential client.
- e. ...
- f. ...
- g. ...
- h. ...
- i. ...

The JWT MAY contain other claims which SHALL be ignored by the Relying Party.

The Relying Party SHALL validate <LogoutRequest> messages as follows:

- j. Verify that the unique identifier of the Issuer matches the one registered for the Verifier.
- k. Verify that the value of the aud parameter matches the Client Identifier of the Relying Party.
- l. Validate the signature according to JSON Web Signature (see fn. 15) using the algorithm specified in the JWT alg Header Parameter.
- m. Verify that the current time is later or equal to the time the the Logout Request was issued by the Verifier.

Relying Parties SHALL sign the <LogoutRequest> message using X.509 certificates issued by a managed Certificate Authority (CA) that is operated according to documented processes detailed in a Certificate Policy (CP) and a Certificate Practice Statement (CSP). The CA's process should meet

²⁰ OpenID Connect RP-Initiated Logout 1.0 - draft 01, August 2020.

the requirements of class 1 certificates defined within the eCH-0048 PKI Certificate Classes standard (Version 2.0).

Verifiers SHALL validate the signature of <LogoutRequest> messages.

4.2.3.9 Logout Response

The <LogoutResponse> message SHALL be send by the Verifier to the Relying Party to confirm session termination.

The <LogoutResponse> message SHALL be compliant with Logout Response message defined in the OpenID Connect back-channel Logout specification (see fn. 13) with the requirements defined in this section.

The <LogoutResponse> message SHALL be signed using recommended cryptographic signature standards. The X.509 certificate used for signatures by the Verifier SHALL be issued by a trusted certificate service provider according to ZertES; SR 943.03 and listed by the Swiss Accreditation Service (SAS).

Relying Parties SHALL validate the signature of <LogoutResponse> messages.

5 Appendix

5.1 List of tables

Table 1: Authentication-Sequence with SAML 2 Artifact Binding.....	12
Table 2: Renewal of a SAML-Response-Assertion with new expiration semantics	12
Table 3: SSO Logout Sequence	13
Table 4: Authentication Sequence with OpenID Connect 1.0 Authorization Code Flow	19
Table 5: OpenID Connect Logout Sequence	19

5.2 List of figures

Figure 1: Authentication-Sequence with SAML 2 Artifact Binding	11
Figure 2: Renewal of a SAML-Assertion	12
Figure 3: SAML 2.0 Logout Sequence	13
Figure 4: Authentication Sequence with OpenID Connect 1.0 Authorization Code Flow	18
Figure 5: OpenID Connect Logout Sequence	19

5.3 Acronyms

Acronym	Definition
EPR	Electronic Patient Record
EIM	Electronic Identification Means
EPRO	Ordinance on the Electronic Patient Record
EPRA	Federal Act on Electronic Patient Records
GLN	GS1 Global Location Number
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
ID	Identifier is either a unique data object or a unique class of objects, which a set of attributes that uniquely describe an entity within a given context.
IdP	Identity Provider
LoA	Level of Assurance
NIST	National Institute of Standards and Technology
RP	Relying Party
SAML	Security Assertion Markup Language
SMS	Short Message Service
SQL	Structured Query Language
TLS	Transport Layer Security
TOE	Target of Evaluation
XML	Extensible Markup Language

5.4 Glossary

Term	Definition
Activation secret	Activation secret, such as a PIN or biometric, may be required to activate the authenticator and permit generation of an authenticator output.
Artifact Binding	In the HTTP Artifact binding, the SAML request, the SAML response, or both are transmitted by reference using a small stand-in called an artifact. A separate, synchronous binding, such as the SAML SOAP binding, is used to exchange the artifact for the actual protocol message using the artifact resolution protocol defined in the SAML assertions and protocols specification [SAMLCore]. (Bindings for the OASIS Security Assertion Markup Language (SAML) V2.0)

Term	Definition
Assertion	Statement made by an entity without accompanying evidence of its validity. NOTE The meaning of the terms claim and assertion are generally agreed to be somewhat similar but with slightly different meanings. For the purposes of this International Standard, an assertion is considered to be a stronger statement than a claim (see fn. 1).
Assertion Data	A data object from a Verifier or Credential Service Provider to a Relying Party (RP) that contains identity information about a Claimant/Subscriber. Assertions may also contain verified attributes.
Assets	Entities that the owner of the Target of Evaluation presumably places value upon. (CC Part 1)
Authentication	Provision of assurance in the identity of an entity (see fn. 1).
Authentication Data	Information used to verify the claimed identity of a user. (CC Part 1)
Authentication Factor	Piece of information and/or process used to authenticate or verify the identity of an entity. NOTE Authentication factors are divided into four categories: something an entity has (e.g., device signature, passport, hardware device containing a credential, private key) (see fn. 1); something an entity knows (e.g., password, PIN); something an entity is (e.g., biometric characteristic); something an entity typically does (e.g., behavior pattern).
Authenticator	Something that the Claimant possesses and controls (typically a cryptographic module or password) that is used to authenticate the Claimant's identity.
Authoritative Source	Repository which is recognized as being an accurate and up-to-date source of information (see fn. 1).
back-channel	Communication between two systems that relies on a direct connection (allowing for standard protocol-level proxies), without using redirects through an intermediary such as a browser. This can be accomplished using HTTP requests and responses.
Binding, Protocol Binding	Generically, a specification of the mapping of some given protocol's messages, and perhaps message exchange patterns, onto another protocol, in a concrete fashion. For example, the mapping of the SAML <AuthnRequest> message onto HTTP is one example of a binding. The mapping of that same SAML message onto SOAP is another binding. In the SAML context, each binding is given a name in the pattern "SAML xxx binding". (SAML Glossary)
Credential	Set of data presented as evidence of a claimed or asserted identity and/or entitlements (see fn. 1). An object or data structure that authoritatively binds an identity (and optionally, additional attributes) to a token possessed and controlled by a Subscriber (see fn. 2).
Federation	This term is used in two senses in SAML: a) The act of establishing a relationship between two entities. b) An association comprising any number of service providers and identity providers. (SAML Glossary)
front-channel	Communication between two systems that relies on redirects through an intermediary such as a browser.
Identifier	One or more attributes that uniquely characterize an entity in a specific context (see fn. 1).
Identity	Set of attributes related to an entity (see fn. 1).
SAML Artifact	A small, fixed-size, structured data object pointing to a typically larger, variably-sized SAML protocol message.

Term	Definition
	(SAML Glossary)
Secret/Private Credential	Credentials that cannot be disclosed by a Credential Service Provider or disseminate to the public because the contents can be used to compromise the authenticator.
Security Attribute	Property of subjects, users (including external IT products), objects, information, sessions and/or resources that is used defining the SFRs and whose values are used in enforcing the SFRs. (CC Part 1) Relevant security attributes in this Protection Profile include reference of the user credential, ID of the Claimant as well as identification data.
Token output / authenticator	The output value generated by a token. The ability to generate valid token authenticators on demand proves that the Claimant possesses and controls the token. Protocol messages sent to the Verifier are dependent upon the token authenticator, but they may or may not explicitly contain it.